

Security Goals

CS494: Security of and with GenAI-based Systems

Notes before we begin

- Password for lecture slides: agentsecurity
- No mention of AI in this class. Just for attention on cybersecurity.
- Last few minutes on Project

So what does it mean for a software system to be secure?

Does it make sense to make claims like "*System X is secure*"?

Poll: Do you think that a fully secure system exists?

- A. Yes
- B. No
- C. May be
- D. Do not know

Short Answer

Do you think the Amazon app is secure? If yes/no, say so and why? (2 lines or less)

Security is Relative!

Security is not a static feature on which everyone agrees.

Security is **relative** – there is no such thing as 100% security.

Because any system, no matter "*how secure*," can be broken.

So we should rephrase the question:

Secure against what, and whom?

Understanding Security

Security is best understood by thinking about goals:

- What is it we are trying to **protect**?
- From **whom** are we protecting?
- **How** can we get the protection we want?

Revisiting the Amazon example

Protection is enforced on Amazon's assets (customer data, financial information, website records)

Protection is sought from external users, Amazon's employees are trusted

Can provide a high degree of protection, but there is no silver bullet defense

The Three Main Goals

Confidentiality

Integrity

Availability

Confidentiality

Information does not land in unauthorized hands.

Amazon.com uses data-mining of your purchase history to determine what to display when you visit.

Web users want to protect their online habits from search engines, ISPs, and cookie trackers. (*What are cookies?*)

Imagine someone records all your web search queries – isn't that a snapshot of your personality?

How about what you ask on medical health websites?

Systems have evolved such that many individuals don't understand what implications confidentiality breaches could have.

Privacy

Privacy is the *right of an individual to control his/her information and not have it divulged or used by others against the individual's wish.*

Confidentiality is usually *the means of protecting such information* (such as using encryption).

Short Answer: Do you think your University email is confidential?

If yes/no, say so and why? (2 lines or less)

Authentication

A related concept is authentication.

Authentication is the process of verifying one's identity. "You are who you say you are."

How many of you have received *Paypal security alerts* saying your account has missing information?

Authentication is a critical software security problem occurring at several different levels – banks, frequent flyers, newspaper subscriptions.

Poll: Secure website

Let's say you are visiting the URL `https://www.amazon.com` with a lock icon on the browser, indicating the connection is secure.

Given this, can you go ahead and input confidential data (e.g. your credit card) ?

- A. Yes
- B. No
- C. May be
- D. Do not know

Integrity

About knowing whether something has been **modified since its creation**.

How do you know if the files you store on the cloud have not been modified since the last time you edited them?

How do you know stock prices you get online are correct? What if data is tampered in transit?

The more our society depends on networked information, the more important integrity concerns become.

Short answer: Login to a machine in a public cafe

You have a need to check email in a place where you don't have mobile signal reception. There is a cafe with a public computer? Would you use that computer to login and check email? If yes, say why you think it is secure. If no, say why you will not.

Availability

Making sure services are **available when they are needed**.

You go to an ATM at midnight for an emergency – how will you react if someone tampered the machine and made it unavailable?

You try to log in to your department server, only to find hackers overwhelmed it with connection requests and forced it to shut down!

Availability refers to something being available, as and when needed, at the required Quality of Service.

Difficult to accomplish because it is harder to distinguish legitimate requests from bad ones.

Short answer: DMV Token Server attack

A DMV office server issues tokens to visitors upon entry. Tokens are awarded to those who sign up with their names and email addresses. Service is limited to one thousand tokens a day. Describe how a malicious visitor can render the token server out of service. Write down a scheme to prevent this attack?

Incident Prevention

Much more attention is paid to security *after* something happens than *before*.

Internet time affects the software development cycle. An attack found spreads like wildfire – a hacker getting attack code simply has to "push button."

Main bottleneck is system development time. To develop a fix, developers sometimes take weeks or months – clearly not enough for sub-second Internet-based attacks.

Automatic Internet-based attacks have become more common – managing these risks is an important problem.

Short answer: How to fix and redeploy?

Developing fixes for patches is bottlenecked by human efforts and the associated development time. If automatic patching (through AI or other means) technology is available, what would be the main issue in deploying it?

Attack Traceability

Attacks will happen, no matter what levels of defense are employed.

Recovering from an attack requires knowing **who did what, and when they did it**.

Auditing does not prevent attacks, but puts a psychological dissuading effect on attackers.

Very similar to double-entry bookkeeping – they help detect, dissect, and demonstrate that an attack occurred.

More importantly, they form **crucial evidence in court proceedings**.

Monitoring

Monitoring is **real-time auditing**.

An example of a monitoring system is an *Intrusion Detection System (IDS)*.

Very similar to a burglar alarm. Crucial factor in deployment is the **false alarm rate**.

Uses a variety of techniques – signatures, in-line checks, and so on.

Has the potential to prevent serious damage.

Project discussion

High level project ideas:

- Security Analysis (and bug finding) of open source applications using AI.
- Secure Agentic Software development
- Agentic framework Capability Enhancement ?